

"Salla Store" E-commerce Project

Case Study:

Project Name: Salla Store

Sector: E-commerce (selling innovative electronic products and smart devices online).

Objective: To provide a secure and reliable e-commerce platform that ensures the protection of customer data, the integrity of transactions, and business continuity.

Key Security Challenges:

- Protecting personal and financial customer data (credit cards).
 - Ensuring transaction integrity and preventing fraud.
 - Providing continuous and available service (preventing DDoS attacks).
 - Protecting intellectual property of products and supplier contracts.
 - Complying with data protection regulations (such as GDPR or local equivalents).
-

Applying ISO/IEC 27001 Requirements to "Salla Store"

We will review the previously discussed requirements and controls and how "Salla Store" will implement them, specifying the required evidence.

First: Framework - Context, Interested Parties, and Scope Requirements

1.1. Requirement (4.1): Understanding the Organization and Its Context

- **Description of Application in "Salla Store":**
 - Salla Store management will conduct regular (annual or semi-annual) workshops to assess internal and external factors affecting information security.
 - **Internal Factors:** May include a lack of trained information security staff, outdated infrastructure, multiple departments with different access privileges, employee information security culture.
 - **External Factors:** May include intense competition in the e-commerce market, increasing cyber attack threats, changes in data protection laws, fluctuating customer trust, and relationships with external payment gateways and suppliers.
 - SWOT and PESTLE analyses will be used to identify information security-related risks and opportunities. For example, infrastructure weakness (weakness) may lead to data leakage risks, while increased information security awareness (opportunity) can be leveraged to improve customer trust.

- **Process:** Conduct SWOT and PESTLE analysis during management review meetings (e.g., twice a year).
- **Required Evidence:**
 - **SWOT/PESTLE Analysis Reports:** Written documents containing a detailed analysis of internal and external factors and their impact on information security.
 - **Management Review Meeting Minutes:** Signed minutes documenting analysis discussions, decisions made, and resource allocation for addressing risks and opportunities.
 - **Risk and Opportunity Registers:** A dynamic document recording identified security risks, their assessment, treatment plans, and identified opportunities to enhance security.

1.2. Requirement (4.2): Understanding the Needs and Expectations of Interested Parties

- **Description of Application in "Salla Store":**
 - Salla Store will identify key interested parties: customers (most important party), employees, suppliers (for products and services like hosting and payment gateways), regulatory bodies (e.g., ministries of commerce and communications), investors, partners.
 - Information security requirements will be collected from each party. For example, customers expect protection of their financial and personal data, suppliers expect secure communication, and regulatory bodies require compliance with specific laws.
- **Process:** Identify stakeholders and their needs through surveys (for customers), interviews (with management and suppliers), and meetings (with internal teams).
- **Required Evidence:**
 - **Stakeholder Maps:** Documents identifying interested parties, their relationship with the organization, and their main interests.
 - **Documented Requirements:** A detailed list of information security requirements for each interested party, and how they will be met through the ISMS.
 - **Communication Records:** Meeting minutes, emails, or survey reports documenting communication with stakeholders regarding security requirements.

1.3. Requirement (4.3): Determining the Scope of the Information Security Management System (ISMS)

- **Description of Application in "Salla Store":**

- The ISMS scope for Salla Store will include:
 - **Systems:** E-commerce platform (website and applications), Customer Relationship Management (CRM) system, inventory and procurement management systems, online payment systems, database servers, backup systems.
 - **Locations:** Data center (if internal) or utilized cloud hosting services, management and employee offices.
 - **People:** All permanent and contracted employees, suppliers with access to sensitive data.
 - **Data:** Personal and financial customer data, product data, supplier data, operational data.
 - Interfaces and dependencies will be clearly defined, such as reliance on external payment gateways (e.g., Stripe or PayPal), shipping companies, and cloud hosting providers.
 - **Process:** Define the boundaries of the ISMS, considering dependencies and interfaces.
 - **Required Evidence:**
 - **ISMS Scope Document:** A formal document clearly defining the ISMS boundaries, covered assets (information, systems, people), locations, and processes.
 - **System Architecture Diagrams:** Drawings illustrating the different components of Salla Store's infrastructure and the dependencies between them and external systems.
 - **Service Level Agreements (SLAs) and Data Processing Agreements (DPAs) with Third Parties:** Contracts with suppliers and service providers outlining their security responsibilities.
-

Second: Organizational Controls

2.1. Control (5.1): Policies for Information Security

- **Description of Application in "Salla Store":**
 - Salla Store will develop comprehensive information security policies covering areas such as: acceptable use of resources policy, password management policy, backup policy, incident response policy, personal data protection policy.
 - These policies will comply with consumer protection laws and electronic transaction laws in the country where Salla Store operates.

- **Process:** Develop overarching and task-specific policies aligning with legal, regulatory, and organizational needs.
- **Required Evidence:**
 - **Approved Policy Documents:** PDF files or internal documents bearing the approval of senior management (e.g., signed by the CEO or Head of Information Security).
 - **Communication Records:** Emails, notifications on the employee management system, or training records proving that policies have been communicated to all employees.
 - **Policy Review Logs:** A schedule showing the review dates for each policy, reviewers, and any modifications made.

2.2. Control (5.2): Information Security Roles and Responsibilities

- **Description of Application in "Salla Store":**
 - Salla Store will designate an "Information Security Officer" (CISO or Information Security Manager).
 - Information security responsibilities will be defined for each department:
 - **Development Team:** Responsible for writing secure code and conducting penetration tests.
 - **Operations Team:** Responsible for securing servers and networks and managing backups.
 - **Customer Service Team:** Responsible for secure handling of customer data and reporting any suspected security incidents.
 - **Senior Management:** Responsible for providing resources and support for the ISMS.
- **Process:** Clearly define roles, assign responsibilities, and ensure personnel understand their obligations.
- **Required Evidence:**
 - **Role Descriptions:** Documents defining specific security tasks and responsibilities for each job role.
 - **Organizational Charts:** Diagrams showing the management hierarchy and security responsibilities within Salla Store's organizational structure.
 - **Acknowledgement Forms:** Documents signed by employees acknowledging that they have read and understood information security policies and their responsibilities.

- **Training Records:** Records of employee attendance at security awareness training sessions and their responsibilities.

2.3. Control (5.3): Segregation of Duties

- **Description of Application in "Salla Store":**
 - To mitigate risks, critical duties will be separated. For example:
 - The person responsible for developing code will not be the same person responsible for deploying code to the production environment.
 - The person responsible for processing customer orders will not have direct access to credit card databases (handled by the payment gateway).
 - The person responsible for user management and granting permissions will not have full administrative access to all systems.
 - If complete segregation is not possible (e.g., in a small team), compensating controls will be applied, such as the Four-eyes principle or detailed audit logs.
- **Process:** Identify potential conflicts in duties and establish segregation with compensating controls if necessary.
- **Required Evidence:**
 - **Segregation of Duties Policy:** A document outlining the guiding principles for segregation of duties within Salla Store.
 - **Access Control Logs:** Systemic records showing who has access to which system or data, and who performed specific actions.
 - **Audit Reports:** Internal or external reports verifying the implementation of the segregation of duties policy and identifying any violations or loopholes.
 - **Roles and Permissions Matrix:** A table clearly outlining the different roles within the organization and the permissions granted to each role.

2.4. Control (5.4): Management Responsibilities

- **Description of Application in "Salla Store":**
 - Senior management at Salla Store will be committed to supporting information security. This includes:
 - Allocating necessary budget and resources (for training, purchasing security tools, hiring specialists).
 - Participating in periodic information security reviews.
 - Addressing escalated security issues.
 - Fostering a security awareness culture among employees.

- **Process:** Assign and communicate responsibilities, monitor compliance, and provide necessary resources.
 - **Required Evidence:**
 - **Management Meeting Minutes:** Minutes documenting senior management discussions about information security, budget and resource-related decisions, and ISMS performance reviews.
 - **Resource Allocation Records:** Documents proving the allocation of financial and human resources for information security activities (e.g., invoices for security software purchases, employment contracts for security experts).
 - **ISMS Performance Reports:** Periodic reports presented to senior management summarizing the security posture, incidents, compliance, and control effectiveness.
 - **Security Policy Statement Document:** A statement issued by senior management affirming their commitment to information security and its importance to the organization.
-

Conclusion:

Systematically applying these requirements and controls will help "Salla Store" build a robust information security management system, thereby increasing customer trust, protecting critical project assets, and ensuring compliance with legal and regulatory requirements in the evolving e-commerce landscape. The evidence mentioned above is crucial for demonstrating compliance with standards during any internal or external audit.